SECCIÓN 5.1

Cómo leer una alerta sin sacar conclusiones apresuradas

Temas de esta sección:

- Qué representa una alerta y qué NO representa
- Diferencia entre evento, alerta e incidente
- Campos clave: nombre, severidad, fuente, acción del control, timestamp
- El peligro de asumir demasiado rápido
- Niveles de certeza: observado, sospechoso, compatible, probable, confirmado
- Misma alerta, distinto contexto — tres ejemplos aplicados
- Errores comunes al leer alertas

En un SOC, una alerta no es una verdad absoluta. Es una señal generada por una herramienta, una regla o un modelo. El trabajo del analista no es creerle ciegamente. El trabajo es **validarla.**

El analista debe validar:

- ¿Qué ocurrió?
- ¿Qué evidencia tengo?
- ¿Qué contexto falta?
- ¿La actividad tiene sentido?
- ¿Hay riesgo real?
- ¿Corresponde cerrar, monitorear o escalar?

```
Alert: Suspicious PowerShell Execution
Severity: High  |  Host: FIN-LAP-022
User: finanzas.paz  |  Process: powershell.exe  |  Action: Allowed
```

Esto NO alcanza para decir 'el equipo está comprometido'.
Tampoco alcanza para decir 'no pasó nada'.
Lo correcto es analizar.

EVENTO	Una actividad registrada por una fuente.	*Ejemplo: User login success · Process created · DNS query · File created · Network connection*
ALERTA	Una señal generada porque uno o más eventos cumplen una condición de interés.	*Ejemplo: Multiple failed logins followed by success · Office spawned PowerShell · Connection to suspicious domain*
INCIDENTE	Situación donde hay evidencia suficiente de afectación real o potencial sobre CIA o uso no autorizado.	*Ejemplo: Cuenta comprometida con regla de reenvío externa y descarga masiva de archivos de SharePoint.*

No todo evento es una alerta. No toda alerta es un incidente. La distinción define cómo responder.

Antes de decidir si una alerta es crítica, benigna o falsa positiva, hay que leerla completa:

Campo	Por qué importa
Nombre de alerta	Orienta, pero no define la conclusión. Hay que saber qué evento la disparó.
Severidad	Punto de partida, no decisión final. Puede estar desalineada con el riesgo real.
Fuente	EDR, SIEM, DNS, Firewall, Identidad… cada fuente tiene fortalezas y límites.
Usuario / Host	¿Tiene rol técnico? ¿Es endpoint o servidor? ¿Activo crítico? Cambia todo.
Acción del control	Allowed ≠ Blocked. Bloqueado no siempre cierra el caso.
Timestamp y ventana	¿Qué ocurrió antes? ¿Qué después? ¿Fuera de horario? ¿Coincide con cambio?
Proceso / Parent Process	El proceso padre puede revelar la cadena de ejecución inicial.
Técnica MITRE	Ayuda a clasificar el comportamiento. No reemplaza la validación.

5.1 | Severidad de herramienta vs riesgo real

La severidad que muestra la herramienta no siempre coincide con la severidad real:

Severity: HIGH (herramienta)

```
Alert: Suspicious PowerShell
User: soporte.admin
Host: IT-ADM-02
Command: install_security_agent.ps1
Ticket: CHG-2026-3301
```

Severidad real: BAJA → Actividad autorizada. Contexto de despliegue aprobado.

Severity: LOW (herramienta)

```
Alert: Mailbox forwarding rule
User: CFO
Destination: externalmail123@gmail.com
Prev login: Foreign IP
Device: Unknown
```

Severidad real: ALTA → Posible compromiso de cuenta ejecutiva. Regla de exfiltración silenciosa.

La severidad inicial orienta. La severidad real se construye a partir del contexto, el activo, el usuario y la actividad posterior.

Un analista debe diferenciar qué afirma con evidencia y qué plantea como hipótesis:

OBSERVADO	*"Se observó ejecución de PowerShell."*	Hecho registrado. No implica malicia.
SOSPECHOSO	*"La ejecución es sospechosa por el proceso padre y los parámetros."*	Señal que requiere análisis, no confirmación.
COMPATIBLE CON	*"La secuencia es compatible con ejecución inicial mediante documento malicioso."*	Hipótesis sostenida por evidencia múltiple.
PROBABLE	*"La actividad sugiere probable compromiso de cuenta por login anómalo y regla de reenvío."*	Alta sospecha con evidencia convergente.
CONFIRMADO	*"Se confirmó ejecución de malware con persistencia y comunicación externa posterior."*	Evidencia técnica concreta y directa.

5.1 | Misma alerta, distinto contexto

El mismo nombre de alerta puede tener interpretaciones completamente distintas:

CASO 1 → ACTIVIDAD AUTORIZADA

```
Alert: Suspicious PowerShell Execution
User: soporte.admin
Host: IT-ADM-02
Parent: software_deploy.exe
Command: -File C:\CorpScripts\install_agent.ps1
Ticket: CHG-2026-3301 | Action: Allowed
```

→ Cerrar como actividad autorizada.

CASO 2 → ALTA PRIORIDAD

```
Alert: Suspicious PowerShell Execution
User: rrhh.silva
Host: HR-LAP-044
Parent: WINWORD.EXE
Command: -nop -w hidden -enc <base64>
Network: docs-preview-check.net | Action: Allowed
```

→ Escalar o investigar con prioridad.

La alerta tiene el mismo nombre. La interpretación cambia completamente por el contexto: usuario, proceso padre, comando y actividad de red.

Reconocer estos errores desde el principio evita análisis incorrectos:

✘ Cerrar porque la severidad es baja

✔ Severity:Low puede ser crítico (regla de correo del CFO). La severidad de la herramienta no reemplaza el análisis contextual.

✘ Escalar solo porque la severidad es alta

✔ Severity:High puede ser actividad autorizada con ticket. El contexto siempre prevalece sobre el campo de severidad.

✘ Cerrar porque la acción fue Blocked

✔ Un bloqueo reduce el riesgo inmediato, pero no revisa si hubo ejecución previa, persistencia o actividad adicional.

✘ Confirmar incidente por el nombre de la alerta

✔ 'Ransomware behavior detected' es un nombre. Lo que confirma el incidente es la evidencia de comportamiento real.

✘ No leer el proceso padre ni la línea de comandos

✔ Son los campos más discriminantes en alertas de endpoint. Sin ellos, el análisis es incompleto.

✘ No revisar la actividad posterior

✔ El 'antes y después' de una alerta define si hay cadena de ataque o evento aislado.